

Confidentiality Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 C1.1 (Confidentiality — protects info designated as such) · C1.2 (Disposes of confidential info) · HIPAA §164.312 (safeguards) · GDPR Art. 5(1)(f) integrity + confidentiality **Companion documents:** Data Retention & Deletion Policy · Encryption Policy · Access Control Policy · Acceptable Use Policy · Vendor Management Policy · railcall.ai/legal/privacy (customer-facing companion).

1. Purpose

Define what RailCall treats as confidential, how it's handled, and what happens when confidentiality is breached. Written as the operator-internal companion to the customer-facing terms + privacy policy.

2. Classification

Every piece of information touched by RailCall falls into exactly one class. The class determines encryption, access, retention, and disclosure rules.

Class	Definition	Examples	Default handling
PUBLIC	Intended for open distribution	railcall.ai marketing content, published docs, station tarballs on GitHub Releases, this SRA + policy set post-adoption, issuer public key	No encryption required; standard hosting integrity controls apply (checksum + TLS in transit)
INTERNAL	Not for external distribution; leak wouldn't cause direct harm	Draft policies (like this one), incident notes, internal decisions, cost analyses, Probo state, this policy folder before adoption	0600 file perms, git-hosted, no automated external egress
CONFIDENTIAL	External distribution would harm customer or business relationship	Customer email addresses, customer usage metadata, signed BAA texts, Stripe customer records, restricted API tokens, DPA-scoped agreements	Encrypted at rest (Render Postgres managed encryption or vault AES-256-GCM), 0600 files, access via Access Control Policy §6 only
SECRET	Compromise = existential or trust-root failure	Issuer signing seed, individual install signing seeds, Stripe standard secret keys, RailCall_ISSUER_SEED, VPS root SSH key	OS keychain or 1Password only; never written to any file we don't control; rotation runbook in Encryption Policy §7

Anything not obviously PUBLIC is INTERNAL until re-classified. Anything customer-identifying is CONFIDENTIAL. Anything that signs, mints, or grants is SECRET.

3. What we treat as customer confidential

- **Identifying info:** email address, org name, Stripe customer id, IP addresses collected in Render logs.
- **Payment info:** we never see full card numbers (Stripe handles); we DO see subscription state, invoice history, plan, seat count.
- **Usage patterns:** any timing, frequency, or content signal derivable from meter events (`sha256(api_key)`, timestamps, run counts).
- **Configuration:** which integrations they have configured, at what BYOK count (though we never see the credentials themselves — see §5).
- **Incident-related detail:** anything a customer told us during triage.

We do NOT treat as confidential (it's their choice to publish or not): - The customer's decision to be our customer (unless they explicitly ask us not to reference them). - Aggregate + de-identified statistics ("we have N paying customers", "median seat count is X").

4. What we treat as our own confidential

- **INTERNAL:** business plans, revenue figures, unadopted policies, internal team communications, customer names in aggregate stats when not yet redacted.
- **CONFIDENTIAL:** contracts with vendors, individual employee compensation (N/A for a two-person team but stated for future headcount), unshipped code that hasn't been released, competitive analysis.
- **SECRET:** the issuer seed (§164.312 trust root), production credentials for every vendor in Vendor Management §3, private keys of any kind.

5. What we architecturally do NOT hold

Stated explicitly because absence of storage is the strongest confidentiality control:

- **Customer workflow inputs + outputs.** The engine runs on the customer's box. We physically don't have this data.
- **Customer PHI or PII of end-users.** Blocked at construction by `phi_guard` (Encryption Policy §5).
- **Customer BYOK secrets.** They live in the customer's 0600 vault on their machine. We never see the values — only that a credential of a given shape exists (integration name + a hash).
- **Customer workflow structure post-execution.** Receipts are integrity hashes over redacted metadata; the actual workflow topology + parameter values stay on the customer's box.

Consequence: for most customer deployments, RailCall is not a business associate under HIPAA (§160.103) because we do not create, receive, maintain, or transmit PHI on their behalf. See SRA §1 for the full analysis.

6. Handling by class

6.1 PUBLIC

- Distributable freely.
- Integrity matters (customers rely on it) — signed release tarballs, checksum-pinned installer.
- No encryption in transit required, but we use TLS by default anyway.

6.2 INTERNAL

- Stored in git (source code + policies + docs) or in Sami's personal channels (Signal, personal 1Password vault entries for INTERNAL work notes).
- Not shared externally without explicit consideration.
- No customer identifiers appear in INTERNAL artifacts unless the artifact is directly for that customer.

6.3 CONFIDENTIAL

- Encrypted at rest: Render managed Postgres for gateway DB rows; 0600 vault for local storage.
- Access limited per Access Control Policy §6.
- Never appears in logs, error messages, or third-party analytics.
- Shared externally only under a signed agreement (NDA, DPA, BAA) matching the customer relationship.

6.4 SECRET

- Storage per Encryption Policy §4 (OS keychain, 1Password, Render env vars marked `sync: false`).
- Never leaves the environment it's authorized for. The issuer seed lives in Render + Sami's 1Password + Sami's paper backup — nowhere else.
- Rotation runbook per Encryption Policy §7 in case of loss OR suspected compromise.

7. Disclosure

We disclose confidential information externally only when:

1. **Legally required** (subpoena, court order, regulatory production request). Sami consults counsel before responding; where legally permitted, we notify the affected customer before disclosing.
2. **Contractually required** (a customer's BAA-mandated breach notification; a Stripe-mandated fraud investigation cooperation).
3. **Necessary for the customer's own operation** (customer's engineering lead asks for their subscription-state — we verify identity and provide).
4. **Explicitly authorized by the affected party** (customer says "yes, use us as a case study").

We never disclose to:

- Marketing partners without opt-in.

- Analytics providers without opt-in and de-identification.
- Other customers.
- Investors or advisors, beyond de-identified aggregates.
- Search-indexable channels of any kind.

8. NDAs

- **Inbound (customer sends us their info under NDA):** we honor it. NDA scope becomes part of that customer's CONFIDENTIAL surface until the NDA lapses.
- **Outbound (we send info under NDA):** default templates in `legal/nda-mutual.md` (TO BE CREATED). Standard mutual NDA — 3-year confidentiality window, standard carveouts for publicly-available info + independently-developed info + legally-required disclosure.
- **NDAs are tracked in Probo** (per-vendor entry in the risk register + document link).

9. When confidentiality fails

Cross-reference Incident Response Policy §7 for compromise runbooks. Specifically:

- **PUBLIC integrity failure** (someone tampered with a release tarball on GitHub): the byte-compare in the release ceremony catches this pre-pin. If it slips past: SEV-1, see Change Mgmt §8 + Incident Response §7.7.
- **INTERNAL leak** (draft policy accidentally posted): re-classify what was leaked; assess whether it matters (usually low); update policy if the leak points at a genuine confidentiality process failure.
- **CONFIDENTIAL leak** (customer identifier or usage pattern exposed): SEV-2. Notify affected customer per breach-notification windows in §10 below.
- **SECRET leak** (trust root or production credential): SEV-1. See Incident Response §7.1 (issuer seed) or §7.5 (Stripe key). Rotation runbook + all-customer notification.

10. Breach notification

Windows sync with Incident Response Policy §3 + BAA_DRAFT.md §3.3:

- **Customers with an active BAA:** within 10 days of discovery.
- **Regulators for HIPAA breaches ≥ 500 individuals:** within 60 days per §164.408 (HHS OCR).
- **GDPR supervisory authority for EU personal data breaches:** within 72 hours per Art. 33.
- **State AGs:** varies; assume 30 days as safe default.

- **Public disclosure:** SO decides; default proactive if any customer is affected.

11. Post-employment / post-relationship

- **Operators leaving the team:** all confidential material returned or destroyed (SSH key removal, 1Password vault removal, Render/Stripe team removal per Access Review Policy §5). NDA remains in effect for its stated term.
- **Vendors we stop using:** per Vendor Management Policy §5 offboarding — cut access, extract data, confirm deletion, remove from Vendor Mgmt §3 + BAA Exhibit C.
- **Customers who leave:** account marked inactive per Data Retention Policy §4.1; personal data may be erased on request per §4.2; compliance-retention data kept for the 6-year HIPAA window even after account close.

12. Review

At each station release + at least annually. Classification changes (something INTERNAL becoming CONFIDENTIAL because a customer requested it be treated as such) trigger an immediate re-application of §6 rules to that item.

13. Related documents

- **Data Retention & Deletion Policy** — the retention windows §11 references.
- **Encryption Policy** — the algorithms + key lifecycles that make §6 rules technically enforceable.
- **Access Control Policy** — who has the credentials that reach each class.
- **Acceptable Use Policy §3.3, §4** — the operator-conduct rules that keep §6 from being violated.
- **Incident Response Policy §3, §7** — the response process for §9 confidentiality failures.
- **BAA_DRAFT.md** — the customer-facing legal instrument this policy operationalizes.
- **railcall.ai/legal/privacy** — the customer-facing companion to §3.